



MINISTÉRIO DA EDUCAÇÃO
Secretaria de Educação Profissional e Tecnológica
Instituto Federal de Educação, Ciência e Tecnologia de Mato Grosso do Sul



CURSO SUPERIOR DE TECNOLOGIA EM ANÁLISE E DESENVOLVIMENTO DE SISTEMAS

Adriano Caires Filho
Luis Enrique Chambi Tapia
Rafael Miranda da Silva

SISTEMA DE GERENCIAMENTO DE ATIVOS DE TI - GATI

Documento Consolidado de Requisitos e Projeto

Versão 1.0.0 - Baseline técnica consolidada pré-implementação

Naviraí - MS

2026

Controle do Documento

Item	Definição
Título	Documento Consolidado de Requisitos e Projeto do GATI
Versão	1.0.0 - Consolidado
Data	21/08/2026
Status	Baseline técnica consolidada; implementação ainda não autorizada por este documento
Escopo de consolidação	DRS original + decisões DEC-001 a DEC-024
Documento original	Preservado; não substituído nem sobrescrito
Histórico oficial	historico.md permanece como trilha cronológica das decisões

Fontes normativas do projeto

- Documento Básico de Requisitos do GATI (DRS/DRPS original, fevereiro de 2026).
- guardrail.md v1.0.0 - regras de governança, autorização, consistência e integridade do histórico.
- prompt.md - protocolo técnico, ordem das dependências e regras para o documento consolidado.
- historico.md - decisões DEC-001 a DEC-024, incluindo revisões e complementações formalmente aprovadas.

Princípio de leitura: quando uma decisão posterior revisa uma anterior, este documento apresenta o estado técnico vigente e mantém a referência à DEC responsável pela alteração.

Validação prévia de consistência

Verificação	Resultado
Dependências previstas no protocolo	22/22 concluídas
Decisões registradas	24 (DEC-001 a DEC-024)
IDs ausentes/duplicados	Nenhum
Status das decisões	14 APROVADO; 10 REVISADO; 0 REVOGADO
Conflito RF-006/RNF-008 x RBAC	Resolvido formalmente pela DEC-020; DEC-006 permanece autoridade efetiva da matriz de Modelo Termo
Pendências remanescentes	Existem, mas são pré-implantação/go-live e estão registradas na seção de pendências; não impedem a consolidação documental

A revisão cruzada não identificou conflito arquitetural pendente que impeça a produção desta baseline. Nenhuma lacuna foi preenchida por suposição; itens sem valor organizacional concreto permanecem explicitamente pendentes.

Sumário

Fontes normativas do projeto	2
Validação prévia de consistência	3
Sumário	4
1 Introdução e propósito	7
2 Escopo e fora do escopo	8
2.1 Escopo do MVP	8
2.2 Fora do escopo do MVP	8
3 Visão geral e atores	9
3.1 Atores internos	9
3.2 Atores externos	9
3.3 Atores de sistema	9
4 Requisitos funcionais	11
5 Requisitos não funcionais	13
6 Regras de negócio	15
7 Arquitetura geral	16
8 Stack tecnológica e versões	17
9 Arquitetura de backend e frontend	19
9.1 Backend	19
9.2 Frontend	19
10 Projeto de banco de dados	20
10.1 Princípios de modelagem	20
10.2 DER conceitual oficial	22
10.3 Tabelas e estruturas principais	23
10.4 Constraints e índices	23
10.5 Migrations	23
11 Arquitetura da API	25
11.1 Catálogo consolidado de endpoints v1	25
11.2 Rotas externas de assinatura	27
12 Autenticação	28
13 Autorização e RBAC	29
14 Endpoint / Coletor	31
15 Comunicação Endpoint - Servidor	32
16 Termos de responsabilidade e assinatura	33
17 Gestão de arquivos e evidências	34
18 Serviço de e-mail	35
19 Web scraping de drivers	36
20 Gestão e instalação de drivers	37
21 Infraestrutura da VPS	39
22 Segurança	40
23 Backup, restore, RPO e RTO	41

24 Observabilidade	42
25 Estratégia de testes	43
26 CI/CD	44
27 Ambientes	45
28 UX/UI e fluxos	46
29 Importação de dados	47
30 LGPD e proteção de dados	48
31 Critérios de aceite	49
31.1 Critérios transversais	50
32 Implantação	52
33 Operação e manutenção	53
34 Limitações conhecidas do MVP	54
35 Pendências remanescentes	55
36 Matriz de rastreabilidade	56
37 Registro das principais decisões arquiteturais	57

1 Introdução e propósito

O GATI - Sistema de Gerenciamento de Ativos de TI - é a plataforma central para controle do parque tecnológico da organização. O sistema substitui controles descentralizados, especialmente planilhas, por uma base única, rastreável e auditável para inventário, responsabilidades, movimentações, termos, manutenção, garantias, coleta técnica via Endpoint e atualização controlada de drivers.

Este documento consolida o DRS original e as decisões arquiteturais formalmente aprovadas ao longo das 22 dependências técnicas. Seu objetivo é descrever o estado vigente e implementável do sistema, sem substituir o documento original nem o histórico cronológico das decisões.

Estado do projeto: arquitetura e especificação aprovadas; implementação ainda depende de autorização própria e de itens pré-go-live explicitamente registrados.

2 Escopo e fora do escopo

2.1 Escopo do MVP

- Gestão de inventário de ativos, cadastro manual e importação controlada de novos Ativos.
- Controle do ciclo de vida, status, localização e histórico cronológico de responsáveis/movimentações.
- Processos estruturados de entrega e devolução com acessórios, condições, participantes e Termos.
- Gestão de Termos e aceite eletrônico por e-mail ou presencial, com evidências e imutabilidade após congelamento/assinatura.
- Manutenções e acompanhamento de garantias.
- Gestão básica de Pessoas (colaboradores/terceiros) e importação controlada.
- Coleta técnica por Endpoint Windows quando tecnicamente viável.
- Busca de drivers Dell/Lenovo por scraping controlado e instalação somente após autorização humana.
- Arquivos/evidências privados, auditáveis e protegidos por antivírus.
- Dashboard operacional, auditoria, observabilidade técnica e ambientes segregados.

2.2 Fora do escopo do MVP

- Portal geral logado para funcionários; somente interfaces externas isoladas de assinatura.
- Descoberta ativa de rede pelo servidor central.
- Depreciação/amortização ou funções contábeis de ERP.
- Gestão de RH como fonte primária; integração AD/RH permanece futura.
- Garantia jurídica nativa do mecanismo de aceite; validação jurídica pertence à organização.
- Microsserviços, Kubernetes, service mesh, broker/filas gerais e event sourcing sem necessidade concreta.
- Aplicativo mobile/PWA, dashboard personalizável, kanban, drag-and-drop complexo e outras ampliações não requeridas.
- Automação de BIOS, firmware, aplicações OEM e drivers boot/storage críticos.

3 Visão geral e atores

3.1 Atores internos

Ator	Responsabilidades principais
Administrador	Administração funcional do GATI, usuários de TI, configurações, auditoria, criação/inativação de modelos de Termo, cancelamento de Termos, revogação/substituição de Endpoint e demais ações previstas no RBAC. Não equivale a superuser técnico.
Operador	Operação diária: inventário, Pessoas, manutenções, entregas/devoluções, edição de modelos existentes, Termos enquanto editáveis, arquivos, Endpoints, preparação/autorização/agendamento/rollback de drivers conforme regras aprovadas.

3.2 Atores externos

Ator	Interação
Responsável pelo Equipamento	Não possui login administrativo; recebe/vê/aceita Termos por sessão temporária isolada ou presencialmente.
Acompanhante/Testemunha	Participa apenas do processo de assinatura/validação quando configurado; sem acesso administrativo.

3.3 Atores de sistema

Componente	Função
Endpoint/Agente	Windows Service que coleta dados técnicos e se comunica de forma client-initiated com a VPS.
Agente de Scraping	Rotina interna na VPS que consulta Dell/Lenovo e registra candidatos de drivers; não instala drivers.
GATI Driver xecutorã	Windows Service privilegiado e local, sem rede/Bearer, responsável apenas por operações fechadas de driver.

4 Requisitos funcionais

ID	Nome	Especificação consolidada
RF-001	Gestão de Inventário de Ativos	Cadastrar, editar, visualizar e inativar ativos; suportar Patrimônio, Service Tag, Número de Série, Categoria, Modelo, Localização, Status, garantia e dados patrimoniais definidos. Importação de novos ativos é suportada pela DEC-022.
RF-002	Recepção de Dados via Endpoint Cliente	Receber via API dados técnicos de IP, MAC, hostname, SO, drivers e hardware do Endpoint autenticado e vinculado ao Ativo.
RF-003	Pesquisa e Filtragem Avançada	Pesquisar por Patrimônio, Service Tag, Número de Série, MAC, IP, hostname, responsável, departamento e status; filtros são whitelistados.
RF-004	Registro Histórico de Movimentações	Registrar automaticamente mudanças de responsável, status e localização; histórico é append-only e correções geram novo evento.
RF-005	Gestão de Manutenção e Garantias	Registrar eventos de manutenção, datas, fornecedor, nota fiscal/serviço, defeito e acompanhar garantia.
RF-006	Gestão de Modelos de Termos	Estado efetivo pela DEC-020: Admin consulta/cria/edita/inativa; Operador consulta/edita modelo existente, sem criar/inativar. Variáveis/tags são resolvidas na geração.
RF-007	Processo de Entrega	Wizard de entrega de um ou mais ativos com responsável, local, data, acessórios, acompanhantes opcionais, condições/observações, Termo e signatários.
RF-008	Processo de Devolução	Wizard de devolução com conferência, divergências/avarias, participantes, assinatura e alteração automática de status/desvinculação conforme RN-003.

ID	Nome	Especificação consolidada
RF-009	Coleta de Assinatura via E-mail	Enviar link único e seguro por Resend/SMTP para aceite eletrônico com sessão temporária e evidências.
RF-010	Coleta de Assinatura Presencial	Permitir aceite presencial em interface isolada no navegador da TI quando não houver e-mail válido ou houver indisponibilidade prática.
RF-011	Anexação de Documentos e Evidências	Upload privado de PDF/JPG/JPEG/PNG vinculado a Ativos, Manutenções e processos, com ClamAV e hash.
RF-012	Gestão Básica de Responsáveis (Pessoas)	Cadastro manual ou importação de Nome, Documento, Departamento, Cargo e e-mail opcional; não é sistema mestre de RH.
RF-013	Dashboard de Operações	Mostrar ativos por status, garantias a vencer em 30 dias corridos e Termos pendentes de assinatura.
RF-014	Edição Individual de Termos e Itens	Permitir editar texto e selecionar itens enquanto EM_EDICAO; congelar na emissão; correções posteriores exigem novo Termo/cancelamento documentado.
RF-015	Busca de Drivers via Web Scraping	Consultar páginas oficiais Dell/Lenovo, extrair/normalizar candidatos e registrar falhas; suspender provider em CAPTCHA/WAF/quebra estrutural.
RF-016	Autorização e Agendamento de Drivers	Exigir ação humana autenticada para preparar pacote, autorizar/agendar e executar via Endpoint; não há instalação autônoma pelo scraper.

5 Requisitos não funcionais

ID	Tema	Estado vigente
RNF-001	Autenticação	Área administrativa exige UsuarioTI autenticado. Sessões Django server-side são o mecanismo humano oficial.
RNF-002	Proteção de credenciais	Argon2id para senhas humanas; tokens/segredos de Endpoint não ficam armazenados em plaintext.
RNF-003	Comunicação segura	HTTPS/TLS 1.2+ em produção/staging e em qualquer development não-loopback.
RNF-004	Auditoria	Log imutável de ações críticas com usuário quando disponível, data/hora, ação e IP; falhas pré-identificação podem ter usuario_id nulo.
RNF-005	Integridade de Termos	Termos/itens/assinaturas congelados/assinados são imutáveis; correção por cancelamento documentado + novo Termo.
RNF-006	Disponibilidade	Disponibilidade condicionada ao SLA da Hostinger; arquitetura não promete 100% de uptime.
RNF-007	Backup	Backup diário do PostgreSQL e dos arquivos permanentes, política oficial local na VPS conforme DEC-015.
RNF-008	RBAC	Administrador e Operador com default deny. Revisão efetiva da edição de ModeloTermo registrada na DEC-020.
RNF-009	Desempenho	Pesquisa simples por Patrimônio/Service Tag com referência <3s sob carga normal; homologação em staging representativo com perfil de carga documentado.
RNF-010	Responsividade	Desktop, notebook e tablet; WCAG 2.2 AA como alvo técnico de acessibilidade.
RNF-011	Privacidade/LGPD	Minimização de dados, mascaramento, retenção por finalidade, dados sintéticos fora de produção e governança via ROPA/matriz de retenção.

ID	Tema	Estado vigente
RNF-012	Autenticação de agentes	Bearer token opaco individual por Endpoint, com enrollment pré-autorizado, hash server-side, rotação e revogação.
RNF-013	Scraping	Arquitetura tolerante à volatilidade, logs de falha, suspensão segura diante de mudanças/WAF/CAPTCHA e manutenção manual do adapter quando necessário.

6 Regras de negócio

Regra	Definição consolidada
RN-001	Patrimônio e Service Tag são únicos entre Ativos não inativados.
RN-002	Ativo principal possui no máximo um responsável ativo, salvo categoria que permita múltiplos responsáveis; troca exige fluxo válido.
RN-003	Devolução concluída e assinada altera status para Em Estoque ou Em Manutenção quando houver avaria e encerra responsabilidade anterior.
RN-004	Termos assinados e itens vinculados são imutáveis.
RN-005	Sem e-mail válido, envio por e-mail é bloqueado e assinatura presencial torna-se obrigatória.
RN-006	Dados técnicos do Endpoint têm precedência sobre dados manuais correspondentes.
RN-007	Nenhum driver pode ser instalado autonomamente a partir do scraping; autorização e agendamento humanos são obrigatórios.
RN-008	Ativos, Pessoas e registros históricos sujeitos à rastreabilidade usam inativação/soft delete, não exclusão física operacional.

7 Arquitetura geral

O DRS utiliza terminologia MVC. A implementação Django seguirá seu padrão MTV, mantendo o mesmo princípio de separação: Models representam persistência/estado; Templates representam Views de apresentação; Views/DRF endpoints e camada de serviços realizam controle/orquestração. Controllers conceituais do DRS são mapeados para Views, serviços de aplicação e adapters, sem alterar a separação arquitetural aprovada.

flowchart LR

```
B[Browser TI / Assinatura isolada] --> N[NGINX TLS]
E[Endpoint Windows] --> N
N --> D[Django + Gunicorn]
D --> P[(PostgreSQL 18)]
D --> F[Storage privado]
D --> C[ClamAV]
D --> S[Scraping Dell/Lenovo]
D --> M[Resend SMTP]
E --> X[GATI Driver Executor local]
O[Prometheus/Grafana] --> D
O --> P
```

Diagrama Mermaid - visão lógica consolidada.

8 Stack tecnológica e versões

Camada	Tecnologia	Versão/Linha	Fonte
Backend	Python	3.14.x	DEC-002
Framework web	Django	5.2.x LTS	DEC-002
API	Django REST Framework	3.17.x	DEC-004
Filtros API	django-filter	26.1.x	DEC-004
OpenAPI	drf-spectacular	0.30.x	DEC-004
Frontend	Django Templates	Django 5.2.x	DEC-002
Interatividade	HTMX	2.0.x	DEC-002
UI/CSS	Bootstrap	5.3.x	DEC-002
Banco	PostgreSQL	18.x	DEC-002/003

Camada	Tecnologia	Versão/Linha	Fonte
Endpoint	C# / .NET	.NET 10.x LTS / C# 14	DEC-007
Resiliência Endpoint	Microsoft.Extensions.Http.Resilience	10.x	DEC-008
HTTP scraping	requests	2.34.x	DEC-012
HTML parser	beautifulsoup4	4.15.x	DEC-012
Browser headless	Playwright + Chromium	1.62.x	DEC-012
Antivírus	ClamAV	1.4.x LTS	DEC-010/014
XLSX	openpyxl	3.1.x	DEC-022
Proteção XML	defusedxml	0.7.x	DEC-022
SO produção	Ubuntu Server	26.04 LTS x86_64	DEC-014
Containers	Docker Engine / Compose	29.x / 2.x	DEC-014
Reverse proxy	NGINX OSS	1.30.x	DEC-014
WSGI	Gunicorn	26.x	DEC-014
Métricas	Prometheus	3.13.x LTS	DEC-016
Dashboards	Grafana OSS	13.2.x	DEC-016
Exporters	node_exporter / postgres_exporter	1.12 / 0.20	DEC-016
Cliente métricas Python	prometheus-client	0.26	DEC-016
Testes Python	pytest / pytest-django	9.1 / 4.14	DEC-017
Cobertura	coverage.py	7.15	DEC-017
CI/CD	GitHub.com Free Actions / GHCR	+ serviço hospedado	DEC-018
E-mail	Resend via SMTP	plano/limites sujeitos a revisão	DEC-011/023

Patch updates dentro das linhas aprovadas são permitidos por manutenção controlada; mudança de linha principal exige revisão formal.

9 Arquitetura de backend e frontend

9.1 Backend

- Django monolítico modular como aplicação principal do MVP; não há microsserviços.
- Camada de serviços concentra regras críticas compartilhadas por Views HTML e endpoints DRF.
- Django ORM e migrations são a única fonte oficial de evolução do schema.
- Management commands e systemd timers executam tarefas periódicas/desacopladas apropriadas, sem Celery/Redis no MVP.
- Validação e autorização em múltiplas camadas: formulário/serializer, View/DRF e services para invariantes críticas.

9.2 Frontend

- Django Templates server-rendered, HTMX para interações incrementais e Bootstrap 5.3.x para responsividade.
- HTMX é usado em filtros, paginação parcial, dependências simples, atualização de status e fragments; páginas importantes mantêm URLs estáveis.
- Validação server-side Django é autoridade; validação nativa do navegador pode reforçar UX.
- WCAG 2.2 AA é alvo técnico, não certificação automática.

10 Projeto de banco de dados

10.1 Princípios de modelagem

- BigAutoField/BIGINT para chaves internas padrão; UUIDs são usados quando necessário como identificadores externos/canônicos.
- UsuarioTI customizado desde a migration inicial.
- Pessoa é entidade comum para colaborador, terceiro, responsável e testemunha.
- Ativo patrimonial é separado de AtivoTecnico; InterfaceRede registra MAC/IP.
- Estado atual é separado de Movimentacao append-only e de ProcessoMovimentacao operacional.
- Termo/Termoltem/AssinaturaTermo preservam snapshots e imutabilidade.
- Arquivos usam metadados no PostgreSQL e binários no filesystem privado.
- Submodelos de Endpoint, scraping, drivers, importação e LGPD complementam o DER histórico sem reescrevê-lo.

10.2 DER conceitual oficial

erDiagram

```
USUARIO_TI ||--o{ MOVIMENTACAO : registra
USUARIO_TI ||--o{ LOG_AUDITORIA : executa
USUARIO_TI ||--o{ AGENDAMENTO_INSTALACAO : autoriza
DEPARTAMENTO ||--o{ PESSOA : possui
PESSOA ||--o{ RESPONSABILIDADE_ATIVO : assume
PESSOA ||--o{ PROCESSO_MOVIMENTACAO : responsavel
PESSOA ||--o{ ASSINATURA_TERMOS : assina
CATEGORIA_ATIVO ||--o{ ATIVO : classifica
STATUS_ATIVO ||--o{ ATIVO : estado_atual
LOCALIZACAO ||--o{ ATIVO : local_atual
ATIVO ||--|| ATIVO_TECNICO : possui
ATIVO ||--o{ INTERFACE_REDE : possui
ATIVO ||--o{ DRIVER_INSTALADO : possui
ATIVO ||--o{ RESPONSABILIDADE_ATIVO : atribuido
ATIVO ||--o{ MOVIMENTACAO : historico
ATIVO ||--o{ PROCESSO_ITEM : participa
ATIVO ||--o{ MANUTENCAO : recebe
PROCESSO_MOVIMENTACAO ||--|{ PROCESSO_ITEM : contem
PROCESSO_MOVIMENTACAO ||--o{ TERMO : gera
MODELO_TERMOS ||--o{ TERMO : origina
TERMO ||--|{ TERMO_ITEM : congela
TERMO ||--o{ ASSINATURA_TERMOS : recebe
ATIVO ||--o{ DRIVER_ATUALIZACAO : possui
DRIVER_ATUALIZACAO ||--o{ AGENDAMENTO_INSTALACAO : agenda
```

Este DER é preservado exatamente como referência conceitual da DEC-003. Entidades complementares posteriores são descritas nas subseções seguintes sem reescrever o histórico.

10.3 Tabelas e estruturas principais

Grupo	Estruturas
Núcleo DEC-003	usuario_ti, departamento, pessoa, categoria_ativo, status_ativo, localizacao, ativo, ativo_tecnico, interface_rede, driver_instalado, responsabilidade_ativo, movimentacao, processo_movimentacao, processo_item, modelo_termo, termo, termo_item, assinatura_termo, manutencao, arquivo, ativo_arquivo, manutencao_arquivo, processo_arquivo, log_auditoria, driver_atualizacao, agendamento_instalacao
Complementações aprovadas	endpoint, endpoint_enrollment, endpoint_credential, endpoint_command, endpoint_agent_release, scraping_provider, scraping_execucao, driver_pacote, importacao_execucao

10.4 Constraints e índices

- Unique parcial para Patrimônio e Service Tag entre Ativos não inativados.
- Código de StatusAtivo único; prevenção de duplicidade do mesmo Ativo no mesmo processo.
- Integridade temporal de ResponsabilidadeAtivo e proteção contra responsabilidades simultâneas incompatíveis.
- Movimentacao e LogAuditoria protegidos contra UPDATE/DELETE por aplicação e banco.
- Termos/itens/assinaturas congelados protegidos por aplicação e PostgreSQL.
- Índices baseline em identificadores de Ativo, hostname, MAC/IP, documento/departamento, histórico por Ativo/data, processos/status, Termos/status, manutenção/data, auditoria e agendamentos.
- Índices/subconstraints específicos de Endpoint e drivers devem garantir comandos idempotentes, credenciais válidas e no máximo uma operação ativa de driver por Endpoint quando aplicável.

10.5 Migrations

- Django migrations versionadas em Git são a fonte oficial do schema.
- Migrations não são reescritas silenciosamente após aplicação.
- Promoção lógica: test -> staging -> production.

- Deploy de alto risco utiliza estratégia expand/migrate/new code/contract e preferência por forward-fix.

11 Arquitetura da API

- Django REST Framework 3.17.x; versionamento por URL em /api/v1/ com NamespaceVersioning.
- JSON em snake_case e nomes de recursos em português.
- GET consulta; POST criação/actions; PATCH atualização parcial; sem DELETE físico para entidades sujeitas a inativação/auditoria.
- PageNumberPagination: 50 por página, page_size configurável até 100.
- Filtros, busca e ordenação são explicitamente whitelistados.
- Erros seguem RFC 9457 application/problem+json com type, title, status, detail, instance, code e errors controlados.
- 409 Conflict representa conflito de regra/estado; respostas não revelam SQL, stack trace ou segredos.
- OpenAPI 3.1 gerado por drf-spectacular. Swagger/ReDoc público em produção não é requisito aprovado.

11.1 Catálogo consolidado de endpoints v1

Método	Rota	Finalidade
GET	/api/v1/categorias-ativos/	Catálogo de categorias
GET	/api/v1/status-ativos/	Catálogo de status
GET	/api/v1/localizacoes/	Localizações
GET	/api/v1/departamentos/	Departamentos
GET/POST	/api/v1/ativos/	Listar/criar Ativos
GET/PATCH	/api/v1/ativos/{id}/	Detalhar/editar Ativo
POST	/api/v1/ativos/{id}/inativar/	Inativar Ativo
GET/POST	/api/v1/pessoas/	Listar/criar Pessoas
GET/PATCH	/api/v1/pessoas/{id}/	Detalhar/editar Pessoa
POST	/api/v1/pessoas/{id}/inativar/	Inativar Pessoa
GET	/api/v1/responsabilidades-ativos/	Consultar responsabilidades

Método	Rota	Finalidade
GET	/api/v1/movimentacoes/	Consultar histórico imutável
GET/POST	/api/v1/processos-movimentacao/	Listar/iniciar processos
GET/PATCH	/api/v1/processos-movimentacao/{id}/	Detalhar/editar processo permitido
POST	/api/v1/processos-movimentacao/{id}/concluir/	Concluir fluxo válido
GET/POST	/api/v1/modelos-termo/	Listar/criar modelo conforme RBAC
GET/PATCH	/api/v1/modelos-termo/{id}/	Detalhar/editar modelo
POST	/api/v1/modelos-termo/{id}/inativar/	Inativar modelo - Admin
GET/POST	/api/v1/termos/	Listar/criar Termos
GET/PATCH	/api/v1/termos/{id}/	Detalhar/editar enquanto permitido
POST	/api/v1/termos/{id}/emitir-para-assinatura/	Congelar e emitir
POST	/api/v1/termos/{id}/cancelar/	Cancelar - Admin
POST	/api/v1/assinaturas-termo/{id}/reenviar/	Reemitir convite
POST	/api/v1/assinaturas-termo/{id}/iniciar-presencial/	Iniciar modo presencial
GET/POST	/api/v1/manutencoes/	Listar/criar manutenção
GET/PATCH	/api/v1/manutencoes/{id}/	Detalhar/editar manutenção
GET	/api/v1/logs-auditoria/	Auditoria - Admin/read-only
GET	/api/v1/endpoints/	Consultar Endpoints
GET	/api/v1/endpoints/{id}/	Detalhe Endpoint
POST	/api/v1/ativos/{id}/endpoint-enrollment/	Gerar enrollment inicial
POST	/api/v1/endpoints/{id}/revogar/	Revogar/substituir - Admin
POST	/api/v1/endpoints/enroll/	Bootstrap de enrollment
POST	/api/v1/endpoints/heartbeat/	Heartbeat autenticado
POST	/api/v1/endpoints/credentials/rotate/	Rotação da credencial
POST	/api/v1/endpoints/commands/{id}/ack/	ACK/status idempotente
GET	/api/v1/endpoints/agent-updates/{id}/package/	Pacote de atualização do agente

Método	Rota	Finalidade
POST	/api/v1/coletas-tecnicas/	Coleta técnica vinculada pela credencial
GET	/api/v1/drivers-atualizacoes/	Candidatos de driver
POST	/api/v1/drivers-atualizacoes/{id}/preparar-pacote/	Preparar artefato, sem autorizar
GET/POST	/api/v1/agendamentos-instalacao/	Consultar/autorizar/agendar
POST	/api/v1/agendamentos-instalacao/{id}/reverter/	Solicitar rollback controlado
GET	/api/v1/endpoints/pacotes-drivers/{id}/arquivo/	Download de pacote pelo Endpoint alvo
POST	/api/v1/ativos/{id}/arquivos/	Upload contextual
POST	/api/v1/manutencoes/{id}/arquivos/	Upload contextual
POST	/api/v1/processos-movimentacao/{id}/arquivos/	Upload contextual
GET	/api/v1/arquivos/{id}/download/	Download autorizado

11.2 Rotas externas de assinatura

Método	Rota	Regra
GET/POST	/assinar/iniciar/	Recebe/troca token por sessão temporária; GET não aceita Termo.
GET	/assinar/	Exibe contexto permitido da assinatura.
POST	/assinar/confirmar-identidade/	Confirma últimos 4 dígitos; máximo de 5 tentativas por token.
POST	/assinar/aceitar/	Registra aceite explícito, transacional e idempotente.

12 Autenticação

- Usuários humanos: sessão server-side do Django em banco; não há JWT humano no MVP.
- Login por username ou e-mail; ambos únicos, e-mail obrigatório para UsuarioTI.
- Argon2id como hasher principal; senha mínima de 15 caracteres, bloqueio de senhas comuns/similares, sem regra artificial de composição e sem expiração periódica automática.
- Timeout de inatividade: 1 hora; duração absoluta da sessão: 12 horas.
- Cookie em produção: Secure, HttpOnly, SameSite=Lax, Path=/, host-only. CSRF obrigatório em métodos inseguros.
- Logout somente POST; mudança de senha preserva apenas sessão atual; recuperação invalida sessões antigas e exige novo login.
- Recuperação por PasswordResetTokenGenerator, token one-time de 1 hora, resposta genérica que não revela existência da conta.
- Proteção de força bruta: baseline 5 falhas/15 min por conta+IP, bloqueio temporário de 15 min e limite adicional por IP.
- Eventos de autenticação são auditados; tentativa para identidade inexistente pode ter LogAuditoria.usuario_id nulo com identificador tentado sanitizado.

13 Autorização e RBAC

O GATI utiliza Django Groups + Permissions, exatamente dois perfis funcionais no MVP (Administrador e Operador), um perfil funcional por UsuarioTI e default deny. Administrador funcional não equivale a is_superuser técnico.

Ação	Administrador	Operador
Ativo/Pessoa: consultar/criar/editar/inativar	Sim	Sim
Dados técnicos Endpoint: editar por bypass manual	Não	Não
ResponsabilidadeAtivo: edição direta	Não	Não
Movimentacao: consultar	Sim	Sim
Movimentacao: editar/excluir	Não	Não
Correção histórica por novo evento	Sim	Sim
Entrega/Devolução	Sim	Sim

Ação	Administrador	Operador
ModeloTermo: consultar	Sim	Sim
ModeloTermo: criar	Sim	Não
ModeloTermo: editar existente	Sim	Sim
ModeloTermo: inativar	Sim	Não
Termo: gerar/editar enquanto permitido	Sim	Sim
Termo assinado: alterar	Não	Não
Termo: cancelar	Sim	Não
Manutenção	Sim	Sim
Drivers: consultar/preparar/autorizar/agendar/rollback controlado	Sim	Sim
Alterar hash/publisher/perfil/force/raw args	Não	Não
Endpoint: consultar/enrollment inicial	Sim	Sim
Endpoint: revogar/substituir/re-enroll	Sim	Não
LogAuditoria: consultar	Sim	Não
LogAuditoria: alterar/excluir	Não	Não
Gerenciar UsuarioTI/perfil	Sim	Não
Configurações globais	Sim	Não

RF-006/RNF-008 foram revisados pontualmente pela DEC-020 para preservar esta matriz: Operador pode editar ModeloTermo existente, mas não criar/inativar.

14 Endpoint / Coletor

- C# 14 sobre .NET 10.x LTS; Windows 11 x64 no MVP.
- .NET Worker Service hospedado como Windows Service, sem GUI obrigatória e sem listener TCP/HTTP inbound.
- Serviço principal preferencialmente LocalService; coleta por APIs Windows/.NET e CIM/WMI.
- Módulos internos: Agent Orchestrator, Identity Provider, Collectors, Local State, Communication Client e Update Coordinator.
- agent_instance_id GUID persistente identifica a instalação, mas não autentica; SMBIOS UUID/serial/Service Tag/fabricante/modelo são evidências, não segredos.
- Instalador MSI per-machine; publicação self-contained, single-file, win-x64, Release.
- Executáveis/MSI/updates assinados Authenticode com timestamp; updates são transacionais e verificados antes de aplicar.
- Downgrade automático do próprio agente é proibido; rollback do agente pode usar versão anterior conhecida após falha de health local.
- Program Files para binários e ProgramData para estado mutável; secrets locais protegidos por DPAPI.

15 Comunicação Endpoint - Servidor

- Comunicação exclusivamente client-initiated por HTTPS, via polling/heartbeat; sem WebSocket persistente ou porta inbound.
- endpoint_id UUID canônico server-side é distinto do agent_instance_id e da credencial.
- Enrollment pré-autorizado e vinculado a um Ativo; bootstrap token de 256 bits, one-time, 30 minutos, armazenado somente por hash.
- Credencial operacional: Bearer opaco individual de 32 bytes gerado pelo agente; servidor guarda SHA-256; localmente DPAPI + ACL.
- Validade máxima 90 dias; rotação normal aos 60 dias; sobreposição de até 24 horas; revogação imediata.

- Heartbeat a cada 60s com jitter $\pm 10\%$; coleta no startup, a cada 30 min e após mudança de rede; refresh completo máximo em 6h.
- collection_id UUID + sequence monotônico por agent_instance_id; snapshots antigos não sobrescrevem estado mais novo e reenvios são idempotentes.
- Offline: heartbeats não são acumulados; coletas são coalescidas; ACKs/resultados críticos permanecem em outbox durável de arquivos, quota 50 MB.
- Retry transitório com jitter (~2s/4s/8s) e escalonamento até ~5min; connect timeout 10s, request total 30s em JSON.
- Comandos at-least-once com command_id UUID, deduplicação e estados PENDING/RECEIVED/STARTED/SUCCEDED/FAILED/EXPIRED/CANCELLED ; not_before/expires_at.
- Atualização do agente e pacotes de driver são obtidos somente pela API autenticada do GATI; Bearer nunca é enviado a hostname diferente do GATI.

Estado operacional	Critério por last_seen
ONLINE	≤ 3 minutos
DEGRADED	> 3 e ≤ 10 minutos
OFFLINE	> 10 minutos

16 Termos de responsabilidade e assinatura

Estado	Significado
EM_EDICAO	Texto/itens/signatários ainda podem ser ajustados conforme regras.
AGUARDANDO_ASSINATURAS	Conteúdo congelado; convites/sessões aguardam os aceites obrigatórios.
ASSINADO	Todos os aceites obrigatórios concluídos; evidência imutável.
CANCELADO	Cancelamento documentado; conteúdo/evidências anteriores permanecem preservados.

- Na emissão, texto, Termoltem, snapshots, signatários e papéis são congelados; SHA-256 é calculado sobre payload canônico determinístico.
- Cada AssinaturaTermo recebe token individual de 256 bits, one-time, validade 48h, armazenado somente por hash.
- Link usa token no fragmento; página first-party troca o segredo por sessão temporária via POST e remove o fragmento.
- Sessão externa isolada: cookie Secure/HttpOnly/SameSite=Lax/Path restrito, 30 min de inatividade e 2h absolutas.
- Antes do Termo completo, últimos 4 dígitos do Documento; máximo de 5 tentativas, depois token é invalidado.
- GET nunca registra aceite. POST explícito “Aceitar e assinar” é transacional, idempotente e protegido contra CSRF.
- Evidências incluem termo, pessoa, snapshots nome/documento, papel, método, hash, UTC timestamp, IP, User-Agent e e-mail quando aplicável; token plaintext não é armazenado.
- Assinatura presencial usa interface isolada no navegador da TI e exige reautenticação do UsuarioTI ao retornar.
- Sem e-mail válido, modo e-mail é bloqueado. O sistema não declara o mecanismo como ICP-Brasil/Gov.br/assinatura qualificada.

17 Gestão de arquivos e evidências

- Filesystem privado da VPS via abstração Django Storage; PostgreSQL guarda somente metadados/hashtes/relacionamentos.
- Fora do webroot; downloads sempre autorizados pela aplicação e preferencialmente servidos via NGINX internal/X-Accel após autorização.
- Allowlist: PDF, JPG/JPEG e PNG; limite 25 MiB; um arquivo por request multipart/form-data.
- Pipeline: tamanho/extensão -> quarentena -> MIME real -> SHA-256 -> ClamAV -> promoção atômica -> vínculo funcional.
- ClamAV 1.4.x LTS com clamd/freshclam, preferencialmente Unix socket; fail-closed em indisponibilidade/timeout.
- Bytes DISPONIVEL são imutáveis; correção por novo upload e inativação auditável do vínculo antigo.
- Nome físico é storage_key UUID; nome original é apenas metadado. Sem preview inline no MVP.
- Download como attachment, nome sanitizado, nosniff e cache privado/no-store.
- Binários maliciosos são removidos; temporários/quarentena órfãos podem ser limpos após 24h.
- Pacotes de drivers não usam a entidade Arquivo e têm storage/limites próprios.

18 Serviço de e-mail

- Resend é o provedor transacional selecionado para o MVP, utilizando SMTP padrão e Django SMTP backend.
- TLS implícito porta 465 é preferido; timeout SMTP 10s; segredo exclusivo fora de Git/DB/logs.
- Domínio/subdomínio transacional próprio com SPF, DKIM e DMARC; endereço real será definido antes da implantação.
- Templates versionados no repositório: password_reset e term_signature, sempre text/plain + text/html.
- Assuntos neutros, sem CPF, token, patrimônio, Service Tag ou detalhes excessivos; sem anexos, open tracking ou click tracking.

- Envio síncrono, fail_silently=False, sem broker/retry automático. Reenvio de convite é ação humana; falha SMTP não descongela Termo.
- Sucesso SMTP significa submissão/aceitação pelo provedor, não prova de entrega final.
- DEC-023 condiciona uso do Resend em produção à validação formal de hipótese/mecanismo de transferência internacional aplicável. Se inviável, DEC-011 deve ser revisada antes do go-live.

19 Web scraping de drivers

- Fabricantes do MVP: Dell e Lenovo.
- Providers/adapters independentes: DellScrapingProvider e LenovoScrapingProvider.
- HTTP-first com requests 2.34.x + Beautiful Soup 4.15.x; Playwright 1.62.x/Chromium headless somente quando JS/DOM dinâmico for necessário.
- Execução via management command (scrape_drivers), agendada a cada 24h em produção por systemd timer.
- Máximo de um ativo por fabricante de cada vez; sem paralelismo agressivo. Timeouts HTTP 10s connect/30s read; browser ~30s navegação/~60s total.
- Retry apenas transitório; respeita Retry-After. CAPTCHA/WAF/403 persistente/quebra estrutural suspende provider.
- Não usar captcha solver, proxy rotation, stealth, fingerprint spoofing ou APIs privadas não documentadas.
- Hosts e redirects em allowlist oficial; DOM é entrada não confiável. Browser context isolado e sem segredos da aplicação.
- Scraper coleta metadados e URL oficial, deduplica e registra execuções/resultados; não baixa/instala diretamente o driver.
- Falhas estruturais devem ser observáveis e podem exigir manutenção manual do adapter.

20 Gestão e instalação de drivers

Fluxo oficial: candidato -> download controlado pela VPS -> SHA-256 congelado -> pacote privado -> autorização humana do pacote exato -> download autenticado pelo Endpoint -> trust/preflight Windows -> executor privilegiado restrito -> post-check -> rollback controlado quando aplicável.

- Preparação do pacote não autoriza instalação; URL de origem deve ser HTTPS e pertencer à allowlist do provider. Limite 2 GiB por pacote, streaming.
- Pacote possui SHA-256 imutável; se bytes mudarem, é novo artefato e autorizações anteriores não valem.
- Perfis fechados: PNP_INF, DELL_DUP_DRIVER, LENOVO_PROFILED_DRIVER e MANUAL_ONLY. Sem force/downgrade/raw shell arguments.
- BIOS, firmware, apps OEM e boot/storage critical são MANUAL_ONLY/fora da automação do MVP.
- Autorizar/Agendar somente pacote PRONTO; comando driver_install usa not_before e expires_at = agendado_para + 2h.
- Endpoint baixa somente da API GATI e valida tamanho, SHA-256, assinatura/publisher, OS/arquitetura, device_instance_id, hardware IDs e aplicabilidade.
- GATI Driver Executor roda como LocalSystem, sem rede/Bearer/internet/scraping/API admin, por named pipe com ACL restritiva; rejeita caminhos e operações não enumerados.
- Uma operação de driver por Endpoint; driver_install, driver_rollback e agent_update são mutuamente exclusivos.
- reboot_policy = NEVER_AUTO. Necessidade de reboot gera AGUARDANDO_REINICIO.
- Post-check avalia dispositivo/driver/saúde mínima. Rollback usa DiRollbackDriver quando backup existe; é best-effort, nunca remoção destrutiva automática forçada.
- Instalação tem limite esperado de 30 min; após STARTED, o mesmo command_id não reinicia instalador por falha de comunicação.
- Estados incluem AGENDADO, EM_EXECUCAO, AGUARDANDO_REINICIO, SUCESSO, FALHA, REVERTENDO, REVERTIDO, FALHA_ROLLBACK, INTERVENCAO_MANUAL, EXPIRADO e CANCELADO.

- Retenção: pacote VPS enquanto não terminal + 30 dias após último uso terminal; Endpoint remove pacote terminal +24h; recuperação local até ~30 dias.

21 Infraestrutura da VPS

Componente	Baseline
Provedor/região	Hostinger VPS - Brasil/São Paulo
Capacidade inicial	Classe equivalente a ~2 vCPU, 8 GiB RAM, ~100 GiB NVMe
SO	Ubuntu Server 26.04 LTS x86_64 (Plain OS)
Containers	Docker Engine 29.x + Docker Compose Plugin 2.x; sem orquestrador de cluster
Borda HTTP	NGINX OSS 1.30.x no host como única fronteira pública HTTP/HTTPS
Aplicação	Gunicorn 26.x privado + Django
Banco	PostgreSQL 18 privado, porta 5432 não pública
Antivírus	ClamAV 1.4 em container, acesso local/socket
Scraper	Container isolado Playwright/Chromium
Agendamentos	systemd timers para management commands e tarefas operacionais
Storage	/var/lib/gati/...; secrets em /etc/gati/secrets; deploy em /opt/gati/deploy
TLS	Let's Encrypt; TLS 1.2/1.3; HSTS em produção
Observabilidade	Prometheus/Grafana/exporters privados; nenhum endpoint observability público

- Firewall default-deny para portas não necessárias; SSH restrito a origens administrativas que serão definidas antes da implantação.
- Segredos fora de Git, imagens, banco de negócio e logs; não há exigência de Vault/FDE no MVP.
- Downloads privados validados no Django podem usar NGINX internal/X-Accel para transferência eficiente.
- Não instalar self-hosted runner do GitHub Actions na VPS de produção.

22 Segurança

- Least privilege e separação de funções: GATI Admin != superuser; serviço principal do Endpoint != executor LocalSystem; Grafana/infra admin != RBAC GATI.
- Default deny no RBAC e nas rotas do Endpoint; não confiar em ocultação visual de controles.
- HTTPS obrigatório, cookies seguros, CSRF, Argon2id, throttling, tokens opacos de alta entropia e hashes server-side.
- Uploads em quarentena com allowlist, MIME real, SHA-256, ClamAV fail-closed e storage privado.
- SSRF mitigado por allowlists/redirect validation no scraping e download de drivers.
- Drivers usam hash + trust nativo Windows; nenhum shell arbitrário ou URL OEM é enviado ao executor.
- Logs e erros são sanitizados; tokens, cookies, Authorization, passwords, SQL e stack traces não são expostos.
- Movimentacao, LogAuditoria e evidências assinadas são protegidos por imutabilidade em aplicação/banco.
- OWASP ASVS 5.0 L2 aplicável orienta testes; ZAP baseline é usado na estratégia de segurança.
- Segregação de ambientes impede reutilização de secrets/dados reais fora de production.

23 Backup, restore, RPO e RTO

- Política oficial do MVP é backup local na própria VPS em /var/backups/gati/, conscientemente no mesmo domínio de falha.
- Diariamente: pg_dump formato custom + pg_dumpall globals + cópia dos objetos de arquivos permanentes.
- Pacotes de drivers são cache e ficam fora do backup oficial.
- 14 snapshots diários; escrita em .partial + lock exclusivo + promoção apenas após sucesso; manifests com SHA.

- Testes: restore mensal de banco + amostra de hash de arquivo; simulação trimestral de recuperação.
- RPO <=24h e RTO <=4h somente quando o backup local/área de backup permanece recuperável.
- Não há garantia de RPO/RTO para perda total da VPS/filesystem; essa limitação deve ser explicitada.
- Deploys com migration/risco de schema ou dados exigem backup pré-deploy.
- Após restore, operações de privacidade posteriores ao ponto restaurado devem ser reconciliadas conforme DEC-023.

24 Observabilidade

- Separar LogAuditoria de negócio (imutável) de logs técnicos e métricas.
- Django/Gunicorn em JSON para stdout; NGINX fornece request_id de borda. Docker usa logging driver local.
- Prometheus 3.13.x LTS, Grafana 13.2.x, node_exporter 1.12, postgres_exporter 0.20 e prometheus-client 0.26.
- Retenção Prometheus: 15 dias / 2 GiB. Grafana inicialmente em 127.0.0.1:3000 via SSH tunnel para infra admins.
- Health endpoints: /health/live/, /health/ready/ e /internal/metrics/; metrics não são públicos.
- Monitorar host, containers, PostgreSQL, aplicação, NGINX, ClamAV/storage/scans, scraping, Endpoints, drivers, SMTP, backup e TLS.
- Alertas críticos incluem backup falho, storage baixo, ClamAV indisponível, scraping suspenso, Endpoint offline relevante, FALHA_ROLLBACK/INTERVENCAO_MANUAL, trust failure, timeout e reinício pendente.
- Dashboards: GATI Overview; VPS & Containers; PostgreSQL; Integrations; Endpoints & Drivers.
- Logs técnicos minimizam PII e User-Agent; tokens/cookies/Authorization nunca são registrados.

25 Estratégia de testes

Nível	Escopo principal
Unitário	Serviços/regras puras, validações, parsers, collectors e lógica local do Endpoint.
Integração	Django + PostgreSQL 18 real, constraints, migrations, triggers/imutabilidade, ClamAV/fakes e integrações controladas.
API/Contrato	DRF, OpenAPI, RFC 9457, autenticação/autorização, paginação, filtros e idempotência.
E2E	Playwright Chromium headless sobre fluxos críticos Django/HTMX e assinatura.
Endpoint	C#/.NET: coleta, serviço, enrollment, rotação, offline, update e comunicação.
Windows Lab	Instalação real MSI/driver, reboot, rollback e falhas privilegiadas em ambiente descartável.
Segurança	OWASP ASVS 5.0 L2 aplicável, ZAP baseline, auth/RBAC/CSRF/upload/SSRF/redaction.
Recuperação	Backup/restore, integridade de arquivos, reconciliação LGPD pós-restore.
Desempenho	RNF-009 em staging representativo com dataset sintético e perfil de carga documentado.

- Ferramentas Python: pytest 9.1, pytest-django 4.14, coverage.py 7.15.
- Cobertura mínima: Python 80% linhas / 70% branches; .NET 80% linhas.
- Scraping usa fixtures HTML/DOM determinísticas; smoke live de fabricante é controlado/on-demand.
- E-mail usa locmem/fake SMTP em testes regulares; smoke Resend é controlado e separado.
- Dados pessoais reais de produção não entram em fixtures, CI, screenshots ou traces.

26 CI/CD

- GitHub.com Free com repositório privado, monorepo, GitHub Actions e GHCR.
- main é a única branch permanente; feature/fix/hotfix/chore são curtas. main protegida, PR + pipeline verde + revisão humana do processo.
- Squash Merge; releases por SemVer tags.
- Pipeline de PR executa testes, checks de migrations/coverage e build conforme matriz aprovada, usando runners Linux e Windows hospedados quando necessário.
- Build once/promote by digest: a imagem homologada em staging é exatamente a promovida para production, sem rebuild.
- Continuous Integration + Continuous Delivery; produção não possui auto-deploy irrestrito.
- Deploy de produção manual/autorizado via SSH aprovado, sem runner na VPS, com backup pré-migration quando necessário e health/readiness após deploy.
- Artifact retention comum ~7 dias; releases mantêm corrente + 2 anteriores. Configurações CI/deploy/observability são versionadas.
- Hotfix segue branch curta, pipeline e promoção controlada; DB prefere forward-fix.

27 Ambientes

Ambiente	Host	Dados	Banco	Características
development	Local/workstation	Sintético	PostgreSQL próprio	HTTP apenas loopback; DEBUG=True; e-mail fake; scraping periódico e driver real desabilitados.
test	GitHub Actions efêmero	Sintético	PostgreSQL 18 efêmero	Suítes automatizadas; sem dados reais/SQLite substituto nas integrações pertinentes.
staging	VPS/host separado	Sintético	PostgreSQL próprio	HTTPS; DEBUG=False; paridade técnica; e-mail sink/smoke controlado; homologação; sem driver real fora do Windows Lab.
production	VPS Hostinger aprovada	Real	PostgreSQL próprio	HTTPS; DEBUG=False; secrets reais; Resend condicionado; scraping, Endpoint, driver, backup e observabilidade oficiais.
Windows Lab	VM/workstation/snapshot descartável	Sintético	Vinculado a staging	Testes reais de Endpoint/MSI/driver/rollback/reboot; nunca usar Ativo/Endpoint real de production.

- Segredos, cookies, credenciais SMTP/DB/Endpoint e chaves de deploy são distintos entre ambientes.
- Configuração Django conceitual: base.py, development.py, test.py, staging.py e production.py; GATI_ENV com fail-safe para valor desconhecido.
- Staging exibe texto persistente “AMBIENTE DE HOMOLOGAÇÃO”.
- Para RNF-009, staging precisa de capacidade ~2 vCPU/8 GiB e storage comparável, além de perfil_carga_homologacao baseado no volume real esperado.
- Migrations seguem test -> staging -> production; ALLOWED_HOSTS/CSRF_TRUSTED_ORIGINS são explícitos por ambiente.
- Nenhum dump bruto de produção é fluxo normal para dev/test/staging.

28 UX/UI e fluxos

Navegação principal	Conteúdo
Dashboard	Resumo operacional
Inventário	Ativos, detalhe/hub e importação contextual
Pessoas	Cadastros, vínculos atuais e histórico
Operações	Entregas/Devoluções e Manutenções
Termos	Termos e Modelos de Termo
Endpoints	Status, last_seen, hostname, versão e ações por perfil
Atualizações de Drivers	Candidatos, pacotes, autorização/agendamento, resultado/rollback
Administração - Admin	Usuários de TI, Auditoria e Configurações

- Listagens: título, ação primária, pesquisa, filtros ativos, tabela e paginação server-side; sem infinite scroll.
- Detalhe do Ativo: Visão Geral, Técnico, Responsabilidade, Histórico, Manutenções, Arquivos, Endpoint e Drivers.
- Wizard Entrega/Devolução em sete etapas: Contexto; Responsável; Ativos/acessórios; Condições/observações; Termo; Signatários/método; Revisão; depois “Emitir para assinatura”.
- Confirmações de alto impacto são contextuais: inativar, cancelar/emitir Termo, revogar/substituir Endpoint, autorizar driver e rollback.
- Assinatura por e-mail e presencial usa interface isolada, sem shell administrativo.
- Erros corrigíveis ficam inline; estados críticos permanecem visíveis; toasts não são única representação de falhas graves.
- Dados do Endpoint são identificados visualmente como origem autoritativa; Termo assinado não mostra controles de edição.
- Arquivos não têm preview inline no MVP; drivers não oferecem URL/shell/force/downgrade.

29 Importação de dados

- Entidades suportadas: Pessoas e Ativos. Operação exclusivamente CREATE-only; sem update, merge, reativação ou upsert.
- Formatos: CSV e XLSX. CSV oficial UTF-8 (BOM aceito), template com ; e parsing inequívoco de ; ou ,. XLSX somente .xlsx.
- Templates oficiais por entidade; não há mapeamento visual arbitrário de colunas.
- Pessoas: nome, documento, departamento, cargo e e-mail opcional. Ativos: patrimônio, service_tag, numero_serie, categoria, modelo, localizacao, status_codigo, garantia_fim no baseline V1.
- Dados técnicos de Endpoint (IP/MAC/hostname/SO/RAM/drivers etc.) são proibidos na importação administrativa e geram coluna desconhecida.
- Referências (Departamento/Categoria/Localização/Status) devem existir e ser resolvidas estritamente; sem fuzzy matching ou auto-criação.
- Limites MVP: 10 MiB, 5.000 linhas, 1 entidade/arquivo, 1 arquivo/importação. XLSX expandido limitado a 100 MiB.
- Fórmulas/macros/conteúdo ativo são rejeitados. openpyxl 3.1.x + defusedxml 0.7.x; ClamAV obrigatório fail-closed.
- Fluxo: upload temporário -> segurança -> parsing -> validação -> preview -> confirmação explícita -> revalidação -> transação atômica.
- All-or-nothing por arquivo: qualquer erro bloqueante impede criação de todos os registros; conflito concorrente no commit gera rollback completo.
- Duplicidade interna ou registro existente/inativo gera conflito; não existe “última linha vence”.
- importacao_execucao guarda apenas metadados agregados e hash/tamanho/status; arquivo original e conteúdo completo de linhas não são persistidos.
- Arquivos temporários ficam em área privada, fora do backup; removidos após conclusão/cancelamento, até 1h aguardando confirmação e cleanup máximo 24h após resíduo/crash.
- Processamento síncrono no MVP; sem Celery/Redis/fila dedicada.

30 LGPD e proteção de dados

- Princípios técnicos: finalidade, necessidade/minimização, transparência, segurança, prevenção e prestação de contas.
- Pessoa base mantém Nome, Documento, Departamento, Cargo e e-mail opcional; não adicionar dados pessoais não requeridos.
- Consentimento não é a base genérica universal do sistema; bases legais/finalidades concretas devem constar no ROPA da organização.
- Distinguir inativação, desidentificação do cadastro mestre e eliminação. Soft delete não equivale a pedido LGPD atendido.
- Pessoa desidentificada pode ter nome/documento/e-mail/departamento/cargo removidos conforme elegibilidade, mantendo chave técnica/relacionamentos necessários.
- Desidentificação é bloqueada se houver finalidade operacional ativa. Termos/assinaturas históricas não são alterados in-place enquanto retidos.
- Documento/CPF é mascarado em listagens comuns; Documento histórico completo, IP bruto e User-Agent bruto de evidências são Admin-only por padrão.
- LogAuditoria preserva IP quando exigido pelo RNF-004, com acesso Admin-only e retenção conforme matriz organizacional.
- Logs técnicos minimizam PII/User-Agent; tokens/cookies/Authorization/CPF não são registrados desnecessariamente.
- ROPA, matriz de retenção, Aviso de Privacidade e procedimento de direitos/incidentes são documentação obrigatória antes de produção.
- Direitos dos titulares seguem canal organizacional/Encarregado; não há portal público LGPD no MVP. Relatório Admin-only pode ser gerado sob demanda sem cópia permanente.
- Backups anteriores podem conter versão pré-desidentificação até expirar em 14 snapshots; restore exige reconciliação posterior.
- Dados sintéticos são obrigatórios em dev/test/staging/CI.
- Incidentes com dados pessoais devem ser escalados ao Controlador/Encarregado conforme procedimento; o GATI não vira plataforma de gestão de incidentes.
- Resend permanece selecionado, mas produção depende da validação formal do mecanismo aplicável de transferência internacional.

31 Critérios de aceite

A DEC-021 aprovou catálogo CA-RFxxx-yy para RF-001 a RF-016 e critérios transversais CA-TR-*. Abaixo está a baseline consolidada em linguagem Given/When/Then, sem introduzir novo framework BDD obrigatório.

RF	Critério	Given/When/Then consolidado
RF-001	CA-RF001-01	Dado um usuário autorizado e dados válidos de Ativo, quando cadastrar o Ativo, então o registro deve ser criado sem violar a unicidade de Patrimônio/Service Tag e deve permanecer disponível para consulta.
RF-002	CA-RF002-01	Dado um Endpoint autenticado e vinculado, quando enviar coleta com sequence mais novo, então somente o Ativo associado à credencial deve ser atualizado e dados técnicos do agente devem prevalecer sobre equivalentes manuais.
RF-003	CA-RF003-01	Dado o inventário ativo, quando o usuário pesquisar por um critério oficial ou combinação permitida de filtros, então apenas registros compatíveis devem ser retornados e a pesquisa simples deve atender o RNF-009 no ambiente representativo.
RF-004	CA-RF004-01	Dado uma mudança válida de responsável, status ou localização, quando a operação for concluída, então nova Movimentacao deve ser registrada cronologicamente e registros anteriores não podem ser editados/excluídos.
RF-005	CA-RF005-01	Dado um Ativo e um evento de manutenção válido, quando o usuário registrar a manutenção, então datas, fornecedor/descrição e vínculo com o Ativo devem permanecer rastreáveis e a garantia deve poder ser acompanhada.
RF-006	CA-RF006-01	Dado um ModeloTermo existente, quando Administrador ou Operador autorizado editar o modelo, então a nova versão do modelo deve ser salva sem alterar Termos já congelados; criação/inativação continuam Admin-only.
RF-007	CA-RF007-01	Dado um responsável e Ativos elegíveis, quando o wizard de entrega for revisado e emitido, então o Termo deve ser congelado e o processo não deve concluir transições dependentes de assinatura antes de todos os aceites obrigatórios.
RF-008	CA-RF008-01	Dado uma devolução com acessórios/condições informados, quando todas as assinaturas obrigatórias forem concluídas, então a responsabilidade anterior deve ser encerrada e o status do Ativo atualizado conforme RN-003.

RF	Critério	Given/When/Then consolidado
RF-009	CA-RF009-01	Dado um convite por e-mail válido, quando o signatário confirmar identidade e executar POST explícito de aceite dentro da validade, então o aceite deve ser registrado uma única vez, associado ao hash congelado e sem expor/reter o token plaintext.
RF-010	CA-RF010-01	Dado um responsável sem e-mail válido, quando a TI iniciar assinatura presencial, então a interface deve ser isolada, o aceite registrado com evidências e o retorno à administração deve exigir reautenticação do UsuarioTI.
RF-011	CA-RF011-01	Dado um upload permitido <=25 MiB, quando passar MIME/hash/ClamAV, então o arquivo deve ser promovido para DISPONIVEL e tornar-se imutável; falha de scanner/malware deve bloquear a disponibilização.
RF-012	CA-RF012-01	Dado dados válidos de Pessoa, quando Admin ou Operador cadastrar/editar/inativar conforme regras, então o cadastro deve manter apenas dados necessários e vínculos de responsabilidade devem ocorrer por fluxo de negócio, não por edição direta.
RF-013	CA-RF013-01	Dado acesso ao Dashboard, quando a tela carregar, então deve mostrar ativos por status, garantias com vencimento nos próximos 30 dias corridos e Termos pendentes, sem substituir Grafana.
RF-014	CA-RF014-01	Dado um Termo EM_EDICAO, quando texto/itens forem alterados e depois emitidos, então o conteúdo deve ser congelado; após emissão/assinatura não deve haver edição in-place.
RF-015	CA-RF015-01	Dado provider Dell ou Lenovo ativo, quando a rotina buscar metadados em origem oficial, então candidatos devem ser normalizados/deduplicados; CAPTCHA/WAF/quebra estrutural deve suspender/registrar falha sem contorno antibot ou instalação automática.
RF-016	CA-RF016-01	Dado pacote PRONTO com hash congelado, quando Admin ou Operador autorizar e agendar para Endpoint elegível, então o comando deve respeitar janela, trust/preflight, executor fechado, deduplicação por command_id e registrar resultado/rollback quando aplicável.

31.1 Critérios transversais

ID	Regra
CA-TR-001	Área administrativa exige autenticação válida de UsuarioTI.
CA-TR-002	RBAC é aplicado no backend; ocultação de botão não é controle suficiente.

ID	Regra
CA-TR-003	Operação sem permissão é negada mesmo por chamada direta à API/serviço.
CA-TR-004	Registros sob RN-008 usam inativação em vez de exclusão física operacional.
CA-TR-005	Ações críticas do RNF-004 geram LogAuditoria imutável com o contexto exigido.
CA-TR-006	Erros não expõem stack trace, SQL, tokens, senhas ou segredos.
CA-TR-007	Tráfego de produção navegador/agente-servidor utiliza HTTPS.
CA-TR-008	Operações críticas repetíveis respeitam idempotência quando definida.
CA-IMP-001	Upload de importação sem confirmação não altera o domínio.
CA-IMP-002	Confirmação de importação é atômica.
CA-IMP-003	Conflito concorrente antes do commit é detectado e causa rollback.
CA-IMP-004	Arquivo de importação inseguro não é parseado/importado.
CA-IMP-005	Importação concluída é rastreável por execução/auditoria.
CA-LGPD-001..008	Cobrem minimização, mascaramento, evidência restrita, desidentificação segura/bloqueada, imutabilidade histórica, relatório do titular e testes sem dados reais.

32 Implantação

1. Provisionar production na VPS Hostinger conforme DEC-014 e staging em host/VPS separado conforme DEC-024.
2. Definir domínio institucional real, hostnames de staging/production, DNS, SPF/DKIM/DMARC e certificados TLS.
3. Definir origens administrativas permitidas para SSH e regras finais de firewall.
4. Provisionar diretórios, secrets, volumes, PostgreSQL, NGINX, Unicorn, ClamAV, scraper e observabilidade com configuração versionada.
5. Executar migrations versionadas e seed apenas de dados estruturais necessários; criar UsuarioTI bootstrap por procedimento controlado.

6. Configurar Resend somente após validação da condição da DEC-023.
7. Validar /health/live/, /health/ready/, métricas privadas, backup e restauração antes do go-live.
8. Homologar funcionalmente em staging, executar perfil de carga do RNF-009 e ensaios Windows Lab aplicáveis.
9. Promover o mesmo digest homologado para production mediante deploy manual/autorizado e backup pré-deploy quando houver risco de schema/dados.

33 Operação e manutenção

- Aplicar patches compatíveis dentro das linhas aprovadas de forma controlada; mudanças major/minor exigem revisão.
- Acompanhar dashboards/alertas e health checks; Grafana é ferramenta de infraestrutura, não dashboard operacional do usuário final.
- Monitorar capacidade do disco, PostgreSQL, ClamAV, scraping, SMTP, Endpoint, drivers e backups.
- Testar restores mensalmente e simulação de recuperação trimestralmente.
- Manter scrapers por provider quando fabricantes alterarem DOM/WAF; não contornar mecanismos antibot.
- Rotacionar credenciais de Endpoint conforme protocolo e revogar imediatamente em comprometimento.
- Operações de driver graves permanecem visíveis até resolução; FALHA_ROLLBACK/INTERVENCAO_MANUAL exigem tratamento humano.
- Manter ROPA, matriz de retenção, Aviso de Privacidade e procedimentos organizacionais atualizados antes e durante produção.

34 Limitações conhecidas do MVP

- Backup oficial é local à mesma VPS; perda total da VPS/filesystem pode eliminar produção e cópias locais, sem RPO/RTO garantidos nesse cenário.
- Resend depende de validação jurídica/contratual de transferência internacional antes do uso produtivo.
- Web scraping pode parar diante de mudança de layout, WAF ou CAPTCHA e exigir manutenção manual.
- Rollback de driver é best-effort e depende de backup/recursos nativos do Windows; alguns casos exigirão intervenção manual.
- Endpoint suporta Windows 11 x64 no MVP; Linux/macOS/ARM64 ficam fora do escopo inicial.
- Importação é create-only, all-or-nothing e limitada a 5.000 linhas/10 MiB; não há upsert nem mapeamento livre.
- Não há portal geral de funcionários, PWA/mobile app, integração AD/RH, object storage obrigatório, SIEM, DLP/OCR, feature flags SaaS ou orquestração Kubernetes.
- Prazos jurídicos de retenção não são inventados pelo software; dependem da organização Controladora.
- A validade jurídica do aceite eletrônico deve ser confirmada pela organização para seu contexto de uso.

35 Pendências remanescentes

Marco	Pendência
Antes da implantação	Informar domínio institucional real e hostnames definitivos de staging e production.
Antes da implantação	Definir/provisionar origens administrativas permitidas para SSH conforme firewall/DEC-014.
Antes da homologação formal	Fornecer expectativa real de volume/carga para preencher perfil_carga_homologacao do RNF-009.
Antes do go-live	Controlador/Encarregado/Jurídico aprovar matriz de retenção e ROPA, identidade/contato do responsável e Aviso de Privacidade.
Antes do go-live	Validar hipótese/mecanismo de transferência internacional aplicável ao Resend; revisar DEC-011 se inviável.

Marco	Pendência
Validação organizacional/jurídica	Confirmar retenção das evidências patrimoniais/trabalhistas e suficiência do mecanismo de aceite eletrônico da DEC-009.
Implementação futura	Provisionar concretamente código, banco, migrations, ambientes, pipelines, certificates, secrets, Windows Lab e demais componentes somente mediante autorização de implementação.

36 Matriz de rastreabilidade

Req.	Regra/RNF	DEC principais	Componente	API/Tela	Teste/CA
RF-001	RN-001, RN-008	DEC-003,004,006,019,021,022	Inventário/Ativo	/api/v1/ativos/; tela Inventário	CA-RF001-*; integração/API/E2E
RF-002	RN-006	DEC-007,008,016,017,024	Endpoint/Ativo Tecnico	coletas-tecnicas; Endpoint	CA-RF002-*; API/Endpoint
RF-003	RNF-009	DEC-003,004,016,021,024	Busca/Índices	Inventário filtros	CA-RF003-*; performance staging
RF-004	RN-008	DEC-003,006,016,021	Movimentacao	Histórico do Ativo	CA-RF004-*; DB/integration
RF-005	-	DEC-003,004,006,019,021	Manutencao	Manutenções	CA-RF005-*; integração/E2E
RF-006	RNF-008 revisado	DEC-006,020,021	ModeloTermo	Modelos de Termo	CA-RF006-*; RBAC/E2E
RF-007	RN-002	DEC-003,006,009,019,021	ProcessoMovimentacao/Termo	Wizard Entrega	CA-RF007-*; integração/E2E
RF-008	RN-003	DEC-003,006,009,019,021	Processo/Responsabilidade	Wizard Devolução	CA-RF008-*; integração/E2E
RF-009	RN-004/005	DEC-009,011,019,021,023	AssinaturaTermo/E-mail	Interface assinatura	CA-RF009-*; E2E/security
RF-010	RN-005	DEC-009,019,021	Assinatura presencial	Modo isolado	CA-RF010-*; E2E/security
RF-011	-	DEC-010,014,015,016,017,021	Arquivo/Storage/ClamAV	Arquivos	CA-RF011-*; upload/security
RF-012	RN-008	DEC-003,006,022,023	Pessoa/Importação	Pessoas/Importar	CA-RF012-*; integração/import
RF-013	-	DEC-019,021,024	Dashboard	Dashboard	CA-RF013-*; E2E/performance

Req.	Regra/RNF	DEC principais	Componente	API/Tela	Teste/CA
RF-014	RN-004	DEC-009,019,021	Termo/Termolt em	Termo em edição	CA-RF014-*; E2E/DB
RF-015	RNF-013	DEC-012,014,016,017,021	ScrapingProvider/Execucao	Drivers descoberta	CA-RF015-*; fixtures/smoke
RF-016	RN-007	DEC-007,008,013,016,017,019,021,024	DriverPacote/Agendamento/Executor	Drivers autorização	CA-RF016-*; Windows Lab/security

37 Registro das principais decisões arquiteturais

ID	Data	Área	Status
DEC-001	2026-08-10	Stack — Backend	APROVADO
DEC-002	2026-08-12	Stack — Versões, Frontend e Banco de Dados	APROVADO
DEC-003	2026-08-12	Banco — DER, Modelo Lógico/Físico, Constraints, Índices e Migrations	APROVADO
DEC-004	2026-08-14	API — Endpoints, Métodos HTTP, Contratos JSON, Erros, Paginação e Versionamento	APROVADO
DEC-005	2026-08-14	Autenticação — Sessão, Credenciais, Expiração, Logout, Recuperação e Revisão Pontual de Auditoria	REVISADO
DEC-006	2026-08-14	RBAC — Matriz de Permissões Administrador e Operador	APROVADO
DEC-007	2026-08-16	Endpoint — Linguagem, Arquitetura, Instalação, Atualização e Identificação	APROVADO
DEC-008	2026-08-16	Comunicação Endpoint — Enrollment, Autenticação, Rotação, Heartbeat, Retry, Timeout, Sincronização e Offline	REVISADO
DEC-009	2026-08-16	Termos — Assinatura/Aceite Eletrônico e Presencial no MVP	REVISADO
DEC-010	2026-08-17	Arquivos — Upload, Storage, Formatos, Limites, Antivírus, Integridade e Retenção	REVISADO
DEC-011	2026-08-17	E-mail — Serviço Transacional, SMTP, Segurança e Templates	REVISADO
DEC-012	2026-08-17	Scraping — Fabricantes, Estratégia, Periodicidade, Limites e Fallback	REVISADO
DEC-013	2026-08-18	Drivers — Obtenção Controlada, Confiança, Assinatura/Hash, Instalação, Rollback e Falhas	REVISADO

ID	Data	Área	Status
DEC-014	2026-08-18	VPS/Infraestrutura — SO, Containers, Reverse Proxy, Firewall, Domínio, DNS e TLS	APROVADO
DEC-015	2026-08-18	Backup — Rotina Local na VPS, Retenção, Restore, RPO e RTO	APROVADO
DEC-016	2026-08-18	Observabilidade — Logs Técnicos, Métricas, Alertas, Health Checks e Rastreabilidade Operacional	APROVADO
DEC-017	2026-08-18	Testes — Estratégia Unitária, Integração, E2E, Segurança, Recuperação e Regressão	APROVADO
DEC-018	2026-08-19	CI/CD — Git Workflow, Pipeline, Quality Gates, Releases, Homologação e Produção	APROVADO
DEC-019	2026-08-19	UX/UI — Navegação, Wireframes e Fluxos do MVP	APROVADO
DEC-020	2026-08-19	Crítérios de Aceite — Revisão Pontual de RF-006/RNF-008 para Alinhamento com RBAC	REVISADO
DEC-021	2026-08-19	Crítérios de Aceite — RF-001 a RF-016 e Crítérios Transversais do MVP	APROVADO
DEC-022	2026-08-21	Importação — CSV/XLSX, Estrutura, Validação, Duplicidades e Processamento	REVISADO
DEC-023	2026-08-21	LGPD — Minimização, Retenção, Direitos dos Titulares e Governança de Dados Pessoais	REVISADO
DEC-024	2026-08-21	Ambientes — Development, Test, Staging/Homologação, Production e Windows Lab	APROVADO

O detalhamento cronológico, alternativas descartadas, justificativas completas e cadeia de revisões permanecem no historico.md. Este Documento Consolidado apresenta apenas o estado vigente e a rastreabilidade necessária para entendimento e implementação.

FIM DO DOCUMENTO CONSOLIDADO